

AI GOVERNANCE STARTER KIT

Full Professional Version — Framework, Policies, Templates, and Decision Tools

Document Type: Governance framework + policy templates

Audience: Executive sponsors, compliance officers, IT directors, board members

Version: 2.0 · Last Updated: May 2026

Estimated Read Time: 50 minutes

Table of Contents

1. Why AI Governance Matters Now
2. The Five-Layer Governance Framework
3. Policy Standard 1: AI Usage Policy
4. Policy Standard 2: Data Handling for AI
5. Policy Standard 3: Vendor Approval
6. Policy Standard 4: Incident Response
7. Policy Standard 5: Roles & Responsibilities
8. Tool Evaluation & Approval Workflow
9. Meeting Templates & Agendas
10. RACI Matrix and Decision Log
11. First-90-Days Implementation Plan

1. Why AI Governance Matters Now

AI is already in your organization. Some of it is sanctioned: an enterprise license to Copilot, a customer-support chatbot, an AI feature in your existing CRM. Much of it is not: staff using personal ChatGPT accounts to draft emails, browser extensions auto-summarizing meeting notes, vendors quietly adding AI features to products you already buy. Governance is the practice of replacing that mess with intentional decisions.

1.1 The three failure modes governance prevents

- **Shadow AI** — staff use unapproved tools that expose data the org didn't consent to expose.
- **Vendor drift** — products you bought before AI quietly add AI features that change the data model.
- **Decision opacity** — AI-influenced decisions are made without anyone able to explain why later.

1.2 Governance is not the same as policy

Policy is what you write down. Governance is what you actually do. Both matter. A governance framework gives you:

- Clear roles: who decides what.
- A repeatable workflow: how AI gets approved or rejected.
- Accountability: who owns the consequences.
- Feedback loops: how policy gets updated when reality changes.

1.3 Right-sizing for your organization

This kit is designed to be scaled. Under 25 staff: one accountability owner, simple policy, quarterly review. 25-200 staff: small committee, departmental implementation owners. Over 200: formal review board, dedicated AI program manager.

2. The Five-Layer Governance Framework

Effective AI governance operates at five layers. Skip any one and the others won't hold.

2.1 Layer 1 — Strategic alignment

- AI strategy connects to organizational strategy. What problems are we solving with AI? What problems are we NOT?
- Risk appetite is named explicitly: what categories of risk are we willing to accept?
- Investment thresholds are defined: at what cost does AI procurement require executive approval?

2.2 Layer 2 — Policy

- Written, accessible, brief enough to read.
- Reviewed annually at minimum, updated as needed.
- Five core standards covered in sections 3-7 of this document.

2.3 Layer 3 — Process

- Tool evaluation workflow: how a new AI tool moves from idea to approved use.
- Incident response: what happens when something goes wrong.
- Review cadence: who reviews what, how often.

2.4 Layer 4 — People

- Named roles: AI accountability owner, departmental implementation owners, escalation contacts.
- Training: every staff member knows the policy.
- Champions: power users in each department who model good behavior.

2.5 Layer 5 — Technology

- Approved tool catalog.
- Monitoring and logging.
- Network controls (block unapproved AI domains where appropriate).
- Identity and access management for AI services.

3. Policy Standard 1: AI Usage Policy

This is the foundational employee-facing policy. Aim for one page. Below is a template you can adapt directly.

AI Usage Policy — [Organization Name]

Purpose: To enable safe, productive use of AI tools while protecting confidential information and meeting our compliance obligations.

Scope: All employees, contractors, and volunteers who use AI tools in connection with their work for [Organization].

Approved tools: [List]. Use of any AI tool not on this list requires prior written approval.

Permitted uses: Drafting, summarizing, research, code assistance, and similar tasks, subject to data classification rules below.

Prohibited uses:

- Sharing customer PII, PHI, financial records, or proprietary information with non-enterprise AI tools.
- Allowing AI to make consequential decisions about employment, services, or finances without human review.
- Representing AI-generated content as original work without disclosure where disclosure is required.

Data classification: Public data is fine. Internal and Confidential data requires approved enterprise AI. Restricted data is not permitted in any AI tool without explicit legal review.

Reporting: Report concerns, mistakes, or suspected incidents to [contact]. No-blame culture for near-misses.

Enforcement: Violations may result in [consequences per HR policy]. This policy is reviewed annually.

4. Policy Standard 2: Data Handling for AI

This standard sits between your existing data classification scheme and your AI tools. If you don't have a data classification scheme, see appendix recommendations.

4.1 Required data classification scheme

Class	Description	AI permissions
Public	Marketing materials, public docs	Any AI tool
Internal	Project work, training, plans	Approved enterprise AI
Confidential	Customer data, contracts	Approved enterprise AI with audit log
Restricted	PHI, regulated PII, trade secrets	Not permitted without case-by-case legal approval

4.2 Required controls per data class

- **Public:** No additional controls.
- **Internal:** Approved enterprise AI tool. User identity tied to action.
- **Confidential:** Logging on, retention set, periodic access review.
- **Restricted:** Risk assessment per use case. May require contractual amendment with vendor (BAA for HIPAA).

4.3 Data residency requirements

- Customer data of US persons: stored in US.
- EU residents' data: subject to GDPR rules.
- Maine-specific: review state-level data residency expectations periodically.
- Restricted data: residency may be contractually required.

5. Policy Standard 3: Vendor Approval

No AI vendor in production without going through this workflow. No exceptions.

5.1 The workflow stages

- 1 **Sponsor proposal.** A department head or executive proposes a vendor. They define the problem, expected benefit, and rough budget.
- 2 **Initial screen.** AI accountability owner checks: is this duplicative of an existing approved tool? Does it fit the strategic plan?
- 3 **Security and compliance review.** IT, legal, and compliance evaluate the vendor against the scorecard.
- 4 **Pilot decision.** If review is clean, pilot is authorized with defined success metrics and timeline.
- 5 **Pilot evaluation.** Did the pilot meet success metrics? What was learned?
- 6 **Production approval.** Executive sign-off if pilot succeeded. Documented in the decision log.
- 7 **Annual review.** Each approved vendor is reviewed annually for continued fit.

5.2 Approval thresholds by spend

Annual cost	Approval level
Under \$5K	Department head + AI accountability owner
\$5K-\$25K	AI review committee
\$25K-\$100K	Executive sponsor + committee
Over \$100K	Board / governing body review

6. Policy Standard 4: Incident Response

You will have AI incidents. The question is whether you have a process for them.

6.1 What qualifies as an incident

- Sensitive data shared with an unapproved AI tool.
- AI output that caused harm (financial, reputational, or to an individual).
- Suspected vendor-side breach involving your data.
- AI behavior outside expected parameters (hallucination causing material harm, jailbreaking).
- Compliance violation involving AI.

6.2 Response steps

- 1 Contain — stop the activity, lock accounts if necessary.
- 2 Notify — escalate to the AI accountability owner within 1 hour.
- 3 Document — what happened, what data, who is affected.
- 4 Assess — what notification or disclosure obligations apply?
- 5 Communicate — affected parties per legal counsel.
- 6 Remediate — fix the gap that allowed it to happen.
- 7 Review — written post-mortem within 30 days.

6.3 No-blame standard

Honest reports of near-misses make the org safer. People who hide mistakes make the org less safe. Make this culturally clear and enforce it. Punish willful violations, not honest errors.

7. Policy Standard 5: Roles & Responsibilities

7.1 AI Accountability Owner

- Owns the overall AI governance program.
- Reports to the executive sponsor or board.
- Final reviewer of policy changes.
- Decision-maker on edge cases that don't fit existing policy.

7.2 AI Review Committee

- Meets monthly or as needed.
- Reviews vendor proposals and policy changes.
- Owns the approved tool catalog.
- Reviews incident reports.

7.3 Departmental Implementation Owners

- One per department of meaningful size.
- Day-to-day enforcement of policy in their area.
- First point of contact for staff questions.
- Surfaces emerging use cases to the committee.

7.4 All staff

- Follow the AI usage policy.
- Report incidents and near-misses.
- Complete annual training.
- Escalate questions before acting on uncertainty.

8. Tool Evaluation & Approval Workflow

See section 5 for the abstract version. Below is the operational workflow with documents required at each stage.

Stage	Owner	Required documents
1. Sponsor proposal	Department head	One-page proposal: problem, vendor, expected benefit, budget
2. Initial screen	Accountability owner	Screening memo (yes/no/conditions)
3. Security review	IT / security	Completed scorecard, vendor audit reports
4. Compliance review	Legal / compliance	Compliance assessment memo, DPIA if applicable
5. Pilot authorization	Committee	Pilot plan with success metrics and timeline
6. Pilot evaluation	Sponsor + committee	Pilot results report
7. Production approval	Executive	Final approval memo, addition to tool catalog
8. Annual review	Committee	Annual review summary, decision: continue / modify / retire

9. Meeting Templates & Agendas

9.1 Monthly AI Review Committee agenda

- Approvals & rejections since last meeting (5 min)
- Active pilots: status updates (10 min)
- Incidents and near-misses (10 min)
- Policy questions / proposed changes (15 min)
- Upcoming proposals (15 min)
- Open discussion (5 min)

9.2 Quarterly executive briefing agenda

- AI program health: tools in use, spend, incidents (10 min)
- Key decisions made this quarter (10 min)
- Risks and concerns (10 min)
- Strategic alignment review (10 min)
- Decisions needed from executive (variable)

9.3 Vendor pilot kickoff agenda

- Use case and success metrics (10 min)
- Pilot scope: users, data, duration (10 min)
- Risks and mitigations (10 min)
- Roles and escalation (5 min)
- Decision criteria for production approval (10 min)

10. RACI Matrix and Decision Log

10.1 RACI matrix

R = Responsible (does the work). A = Accountable (owns the outcome). C = Consulted. I = Informed.

Activity	Acct Owner	IT/Security	Legal	Dept Head	Executive
Approve new vendor	A	R	C	C	I
Update policy	A	C	R	C	I
Respond to incident	A	R	C	C	I
Annual policy review	A	C	C	C	R
Train staff	A	C	I	R	I
Procurement (>\$25K)	C	C	C	R	A

10.2 Decision log format

Every governance decision goes in the log. Minimum fields:

- Date
- Decision-maker(s)
- Decision (one sentence)
- Rationale (one paragraph)
- Affected systems or policies
- Review date (when revisit)

11. First-90-Days Implementation Plan

Week 1-2

- Designate the AI accountability owner.
- Audit existing AI use (formal and informal).
- Identify the executive sponsor.
- Get committee membership confirmed.

Week 3-4

- Draft the AI usage policy. Use the template in section 3.
- Define data classification if not already in place.
- Set up the decision log.

Week 5-8

- Adopt the policy formally (board / executive approval).
- Communicate policy to all staff.
- Run all-staff training (30-45 minutes).
- Publish the approved tool catalog.

Week 9-12

- First committee meeting.
- First quarterly executive briefing.
- Process at least one vendor through the new workflow.
- First incident drill / tabletop exercise.

About AI Impact Maine

AI Impact Maine helps Maine businesses, municipalities, and nonprofits assess, plan, and responsibly implement AI. We offer readiness assessments, training programs, policy and governance design, vendor evaluation, and ongoing strategic support.

Get in touch

Email: ahmad@aiimpactmaine.com

Web: aiimpactmaine.com

Book a free 30-minute consultation: aiimpactmaine.com/contact